



HACKER WOMEN

ETHICAL
HACKING

ACTIVIDAD 01

ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

2026 Evaluación de Seguridad · Ethical Hacking

CASO DE ESTUDIO

AURORA MARKET

Evaluación formal de seguridad (pentest) sobre
la aplicación web de comercio electrónico.

- Curso: Ethical Hacking
- Hacker Women

1. OBJETIVO DEL PENTEST

A partir del incidente reportado y del contexto entregado por Aurora Market, se definen tres objetivos concretos para esta evaluación de seguridad:

- Identificar vulnerabilidades técnicas en la aplicación web de Aurora Market (autenticación, control de acceso, gestión de sesiones y validación de datos) que puedan ser explotadas por un atacante externo o interno.
- Determinar si existe exposición real de información sensible de clientes (nombres, correos, teléfonos, direcciones y datos de pedidos) por fallas de control de acceso, confirmando o descartando la causa del incidente reportado por el usuario.
- Evaluar el impacto de negocio de los hallazgos y entregar recomendaciones priorizadas y accionables, para que el equipo de desarrollo pueda remediar los riesgos y fortalecer la confianza de los clientes en la plataforma.

2. ALCANCE

Con base en la información parcial entregada por Aurora Market y en las condiciones establecidas en el encargo, se define el siguiente alcance para la evaluación:

◆ Sí se evaluará

- La aplicación web pública de Aurora Market: registro de usuarios, inicio de sesión, catálogo de productos, carrito de compras, checkout y consulta de pedidos.
- El panel/área administrativa utilizada por el personal para gestionar productos, usuarios y pedidos.
- Los mecanismos de autenticación y autorización, incluyendo la gestión de sesiones y la separación de privilegios entre clientes y empleados.
- La lógica de negocio asociada al acceso a datos de cuentas y pedidos, en particular posibles fallas de control de acceso (por ejemplo, referencias directas a objetos que permitan ver información de otros usuarios), ya que esto se relaciona directamente con el incidente reportado.
- Las APIs o endpoints que dan soporte a la aplicación web, siempre que pertenezcan al dominio o entorno autorizado por Aurora Market.

◆ No se evaluará

- Redes sociales oficiales de la empresa.
- Equipos personales, correos electrónicos o dispositivos de los empleados.
- Proveedores externos, pasarelas de pago o servicios de terceros no incluidos explícitamente en la autorización.
- Cualquier sistema, dominio o infraestructura no mencionado por escrito en el documento de autorización.
- Ataques de denegación de servicio (DoS/DDoS) o cualquier prueba con potencial destructivo.
- Modificación, eliminación o exfiltración real de datos de clientes; toda prueba se realizará con el mínimo impacto posible y, cuando sea viable, con cuentas y datos de prueba.

3. AUTORIZACIÓN Y CONDICIONES

Antes de iniciar cualquier prueba técnica, es indispensable contar con una autorización formal y con reglas claras de actuación ("Rules of Engagement"), que protejan tanto al equipo evaluador como a Aurora Market.

◆ Permisos requeridos

- Documento formal de autorización (carta o contrato de Rules of Engagement) firmado por un responsable de Aurora Market con autoridad para autorizarlo.
- Definición por escrito del alcance exacto: dominios, subdominios, IPs y aplicaciones incluidas en la evaluación.
- Ventanas de horario permitidas para realizar las pruebas técnicas (horarios de menor actividad de la plataforma).

- Contacto de emergencia disponible por parte de Aurora Market durante la ejecución de las pruebas.
- Credenciales de prueba para distintos roles de usuario (cliente, empleado, administrador), si el pentest requiere acceso autenticado.

◆ Condiciones acordadas

- Las pruebas se realizarán únicamente sobre la aplicación web autorizada, sin tocar sistemas fuera del alcance definido.
- No está permitido realizar acciones que interrumpan deliberadamente el funcionamiento de la plataforma.
- No se afectará información real de los clientes; se priorizará el uso de cuentas y datos de prueba.
- Las pruebas se ejecutarán en los horarios de menor actividad acordados con la empresa.
- Toda la información y los hallazgos obtenidos se tratarán de forma confidencial.
- Cualquier hallazgo crítico se comunicará de inmediato al equipo de Aurora Market, sin esperar al informe final.

4. TIPO DE PENTEST

Existen tres enfoques principales para clasificar una evaluación de seguridad, según el nivel de información con el que cuenta el equipo evaluador:

- Black-box: el evaluador no tiene conocimiento previo de la infraestructura, el código o las configuraciones; simula a un atacante externo completamente ajeno al sistema.
- Gray-box: el evaluador cuenta con información parcial, como credenciales de usuario o algunos datos generales de la aplicación, pero no conoce todos los detalles internos ni el código fuente.
- White-box: el evaluador tiene conocimiento completo de la infraestructura, el código fuente y las configuraciones, lo que permite una revisión mucho más profunda y exhaustiva.

Tipo de pentest elegido: **Black-box**

Justificación: si bien Aurora Market mencionó al equipo que existe una aplicación web, una base de datos, mecanismos de autenticación y distintos tipos de usuarios, esta información es únicamente conceptual y no constituye un insumo técnico real: es prácticamente lo mismo que podría inferir cualquier visitante externo al ver que el sitio tiene un formulario de login, un catálogo y la opción de registrarse. La empresa no entregó credenciales de prueba, documentación técnica, código fuente ni detalles de arquitectura o configuración, que son justamente los elementos que definen un enfoque gray-box según la clasificación utilizada. Al no contar con ningún acceso ni dato técnico privilegiado, el equipo debe iniciar la evaluación exactamente como lo haría un atacante externo sin ningún conocimiento previo del sistema: registrando sus propias cuentas, explorando la aplicación desde cero y descubriendo su funcionamiento únicamente mediante reconocimiento. Esto corresponde a un enfoque black-box. Este enfoque además es coherente con el origen del incidente: fue reportado por un cliente común, sin privilegios especiales ni acceso técnico, lo que confirma que el riesgo relevante a priorizar es justamente el que enfrenta un atacante sin información interna de la plataforma.

5. PLANIFICACIÓN

Antes de ejecutar cualquier prueba técnica, el equipo debe dejar claros los siguientes elementos:

◆ Objetivos

- Confirmar si existe una vulnerabilidad de control de acceso que permita ver información de otras cuentas (origen del incidente reportado).
- Identificar vulnerabilidades adicionales en autenticación, gestión de sesiones y lógica de negocio.

◆ Alcance

- Aplicación web pública y panel administrativo de Aurora Market, según lo definido en la sección 2.

◆ Permisos y condiciones

- Autorización formal firmada, credenciales de prueba y horarios de menor actividad acordados, según lo definido en la sección 3.

◆ Metodología a utilizar

- OWASP Testing Guide (OWASP WSTG), complementada con el marco de referencia OWASP Top 10 (ver sección 7).

◆ Recopilación de información previa

- Dado el enfoque black-box, el equipo no cuenta con credenciales ni documentación previa; toda la información deberá obtenerse mediante reconocimiento pasivo y activo permitido: tecnologías utilizadas, estructura de URLs, formularios expuestos, roles visibles en la interfaz (cliente vs. panel administrativo) y flujos de navegación, así como el registro de cuentas propias de prueba para explorar la aplicación desde la perspectiva de un usuario real.

◆ Recursos necesarios

- Equipo de pentesting con roles y responsabilidades definidos.
- Cuentas de prueba con distintos niveles de privilegio (cliente, empleado, administrador).
- Herramientas de interceptación y análisis de tráfico (por ejemplo, Burp Suite u OWASP ZAP).
- Entorno de pruebas o ventana controlada dentro del ambiente de producción.
- Canal de comunicación directo y ágil con el equipo técnico de Aurora Market.

◆ Programación del pentest

- Definir fechas y horarios de menor actividad para cada fase (reconocimiento, análisis, explotación, post-explotación e informe), dejando tiempo suficiente para documentar los hallazgos antes de la entrega final.

6. FASES DEL PENTEST

Un pentest se ejecuta siguiendo fases ordenadas, para garantizar cobertura, trazabilidad y control sobre el impacto de las pruebas. A continuación se explica cómo se aplicaría cada fase al caso de Aurora Market:

Fase	¿Qué se hace?	Aplicación al caso Aurora Market
1. Reconocimiento	Recolectar información sobre el objetivo sin interactuar de forma intrusiva: estructura del sitio, tecnologías, funcionalidades visibles.	Al ser black-box, esta fase es clave: registrar una cuenta propia, mapear todas las páginas y funcionalidades de la app (registro, login, catálogo, carrito, pedidos, panel admin), e identificar tecnologías usadas y roles de usuario existentes, ya que no se cuenta con esta información de antemano.
2. Análisis de vulnerabilidades	Identificar posibles debilidades de seguridad a partir de lo recolectado, usando pruebas manuales y automatizadas.	Revisar la aplicación en busca de fallos del OWASP Top 10, con foco especial en control de acceso roto (IDOR), gestión de sesiones y validación de entradas, dado el reporte del cliente.
3. Explotación	Intentar aprovechar de forma controlada las vulnerabilidades encontradas, para confirmar que son reales y no falsos positivos.	Intentar acceder a datos de otro usuario (por ejemplo, cambiando un identificador de pedido en la URL) y documentar la evidencia, sin dañar datos reales.
4. Post-explotación	Evaluar el alcance real del compromiso: qué información adicional podría obtener un atacante y si podría escalar privilegios.	Determinar si desde una cuenta de cliente comprometida es posible llegar a datos de otros clientes o incluso a funciones del panel administrativo.
5. Informe	Documentar cada hallazgo con evidencia, nivel de riesgo y recomendaciones claras, en un	Entregar un informe con los hallazgos, su severidad (usando CVSS, ver sección 7), el

Fase	¿Qué se hace?	Aplicación al caso Aurora Market
	lenguaje comprensible para las partes técnicas y de negocio.	impacto de negocio y un plan de remediación priorizado para el equipo de desarrollo de Aurora Market.

7. INVESTIGACIÓN

◆ Metodología: OWASP Testing Guide (OWASP WSTG)

El OWASP Testing Guide (Web Security Testing Guide) es una metodología abierta y ampliamente utilizada, desarrollada por el proyecto OWASP (Open Worldwide Application Security Project), enfocada específicamente en la evaluación de seguridad de aplicaciones web. Organiza las pruebas en categorías como gestión de configuración, autenticación, gestión de sesiones, control de acceso, validación de datos y lógica de negocio, entre otras. Se complementa con el OWASP Top 10, un listado de los diez riesgos de seguridad más críticos y comunes en aplicaciones web (por ejemplo, control de acceso roto, fallos criptográficos e inyección), que sirve como marco de referencia rápido para priorizar qué buscar.

¿Por qué sería útil para este proyecto? Aurora Market es una aplicación web de comercio electrónico con autenticación, distintos tipos de usuario y datos sensibles de clientes; el WSTG cubre de forma estructurada justamente esas áreas (autenticación, sesiones y control de acceso), que están directamente relacionadas con el incidente reportado. Además, usar el OWASP Top 10 como referencia permite comunicar los hallazgos en un lenguaje estandarizado y reconocido, facilitando que la dirección de la empresa entienda la severidad y prioridad de cada riesgo.

◆ Sistema de severidad: CVSS

El CVSS (Common Vulnerability Scoring System) es un estándar abierto utilizado para calificar de forma objetiva y consistente la severidad de una vulnerabilidad. Asigna un puntaje numérico de 0 a 10, calculado a partir de métricas como el vector de ataque, la complejidad para explotarla, los privilegios requeridos, la interacción necesaria del usuario y el impacto sobre la confidencialidad, integridad y disponibilidad del sistema. Este puntaje se traduce en niveles cualitativos de severidad:

- 0.1 – 3.9: Severidad Baja.
- 4.0 – 6.9: Severidad Media.
- 7.0 – 8.9: Severidad Alta.
- 9.0 – 10.0: Severidad Crítica.

Para este proyecto, el uso de CVSS permitirá priorizar los hallazgos del pentest de forma objetiva: por ejemplo, una falla de control de acceso que exponga datos de otros clientes (como la reportada por el usuario) tendería a calificar como severidad Alta o Crítica, dado su impacto directo sobre la confidencialidad de información sensible, lo cual ayudará a Aurora Market a decidir qué corregir primero.

REGISTRO

Este documento fue elaborado como parte de la Actividad 01 · Análisis y planificación del pentest, del curso de Ethical Hacking de Hacker Women Council, en el marco del caso de estudio Aurora Market.

Nombre completo	Fecha
Jessica Payano Castro	04/09/2026